



Introducción

Los ciberataques no son un evento aislado: siguen patrones reconocibles que van desde el engaño a las personas hasta la explotación técnica de sistemas. Conocer estas categorías —qué son, por qué importan y cómo mitigarlas— es la base para diseñar defensas efectivas, tanto a nivel personal como organizacional.

Categorías de Ataque

Categorías	¿Que es?	¿Por que es Relevante?	Riesgo	Mitigación
Malware	Software diseñado para dañar, robar o tomar control de un sistema (virus, gusanos, troyanos, ransomware, spyware).	Es el vector más común de compromiso inicial en incidentes reales; el ransomware en particular puede paralizar operaciones completas.	Pérdida o secuestro de datos, control remoto del equipo, propagación a otros sistemas de la red.	Antivirus/EDR actualizado, parches de seguridad al día, copias de respaldo offline, no ejecutar archivos de origen desconocido.
Ingeniería Social	Manipulación psicológica para que una persona revele información o realice una acción insegura (phishing, pretexting, baiting, vishing).	ataca al eslabón más difícil de corregir — el factor humano; la mayoría de las brechas exitosas comienzan aquí.	robo de credenciales, fraude financiero, acceso inicial para ataques mayores.	capacitación continua, verificación de identidad por canales alternos, autenticación multifactor (MFA), políticas claras de manejo de información sensible.
Ataque a Contraseñas	intentos de obtener o adivinar credenciales (fuerza bruta, diccionario, credential stuffing, keyloggers).	las contraseñas siguen siendo el método de autenticación más usado y, a menudo, el más débil.	acceso no autorizado directo a cuentas y sistemas.	contraseñas largas y únicas, gestor de contraseñas, MFA, límites de intentos de inicio de sesión.
Ataques de Intercepción	interceptar o alterar comunicaciones entre dos partes sin que lo perciban.	compromete la confidencialidad e integridad de los datos en tránsito, especialmente en redes públicas o mal configuradas.	robo de datos en tránsito (sesiones, credenciales), manipulación de la comunicación.	cifrado end-to-end (HTTPS/TLS), evitar redes Wi-Fi públicas sin VPN, certificados válidos.
Denegación de Servicios (DoS/DDoS)	saturar un sistema o red con tráfico o solicitudes para dejarlo inoperante.	no roba datos, pero interrumpe la disponibilidad — uno de los tres pilares de la seguridad (CIA).	caída de servicios críticos, pérdidas económicas y de reputación.	filtrado de tráfico, servicios anti-DDoS (CDN/WAF), redundancia de infraestructura.
Explotación de vulnerabilidades en aplicaciones web	aprovechar fallas en el código o configuración de una aplicación (inyección SQL, XSS, path traversal, control de acceso roto) para acceder a datos o funciones no autorizadas.	conecta directamente con el trabajo práctico del curso — es la categoría donde la teoría se vuelve explotación demostrable.	exposición de datos sensibles, compromiso del servidor, escalamiento de privilegios.	validación estricta de entradas, principio de menor privilegio, pruebas de seguridad (pentesting), actualizaciones constantes.

Esquema de ataque de Ingenieria Social



Ningún ataque ocurre en el vacío: cada categoría explota una falla distinta (humana, técnica o de configuración), y por eso la defensa efectiva combina capas — tecnología, procesos y concientización — en lugar de depender de una sola medida.

Referencias

Cisco Networking Academy. (2023). *Introducción a la ciberseguridad* [Curso en línea]. Cisco. <https://www.netacad.com>